Security policy

Document owner: `Daniel Oliafa`
Security contact email: `Pending setup (temporary contact: founder email on file)`
Company: `LifeTracker`
Version: `1.0`
Effective date: `2026-04-10`
Next review date: `2027-04-10`

1. Purpose and Scope

This document describes the security and privacy controls implemented by `LifeTracker` for the `LifeTracker` application and related infrastructure that process consumer financial data, including data received via Plaid APIs.

Scope includes:

- Web and backend application systems
- Production and non-production cloud assets
- Data stores and backups
- Personnel and contractors with system access

2. Security Governance and Risk Management

- `LifeTracker` maintains documented security policies and operational procedures to identify, mitigate, and monitor information security risk.
- A designated Security Owner is accountable for policy maintenance and risk oversight.
- Risks are tracked in a risk register, prioritized by severity/impact, and assigned owners with remediation target dates.
- Security policies and procedures are reviewed at least annually and after material technical or business changes.

3. Access Control and Identity Management

- Access to production systems and sensitive data is limited by least privilege and role-based permissions.
- Unique user identities are required; shared production admin credentials are prohibited.
- MFA is required for access to critical systems (cloud consoles, code hosting admin, CI/CD admin, production databases, secret management).
- Access is granted based on business need and approval by system/data owners.
- Access reviews are performed at least quarterly for privileged access.
- Access is revoked promptly on termination or role change.

4. Consumer Authentication and MFA

- Consumer authentication controls are enforced in the application before access to account-level data operations.
- MFA for consumers before Plaid Link is: `In rollout by 2026-05-15`.

5. Data Encryption and Key/Secret Handling

- Data in transit is protected with TLS 1.2 or better.
- Consumer data at rest is encrypted using managed cloud encryption controls.
- Sensitive credentials and API secrets are stored in secured environment configuration or approved secret management tools.
- Secrets are not committed to source control.
- Plaid access tokens are stored server-side only and are never exposed to client-side code.

6. Development and Vulnerability Management

- Code changes are reviewed before production deployment.
- Automated dependency vulnerability checks are performed.
- Infrastructure and endpoint vulnerability checks are performed on a recurring cadence.
- Remediation targets:
  - Critical: within 72 hours
  - High: within 14 days
  - Medium: within 30 days
  - Low: normal maintenance cycle
- Exceptions require documented risk acceptance, compensating controls, and expiration date.

7. Monitoring, Logging, and Incident Response

- Security-relevant events are logged where supported, including authentication and privileged operations.
- Alerts are reviewed for suspicious access and service/security failures.
- A defined incident response process is used for detection, triage, containment, investigation, eradication, recovery, and postmortem.
- Security incidents are severity-rated (`SEV-1` to `SEV-4`) with escalation and stakeholder communication procedures.

8. Privacy, Consent, and Consumer Rights

- A privacy policy is maintained for the application where Plaid Link is deployed.
- Consumers are informed and provide consent for data collection, processing, and storage.
- Data is used to provide budgeting, analytics, and related financial management features requested by users.
- Consumers may request account/data deletion through designated support/privacy channels.

Privacy policy URL: `Pending publication before production launch`

9. Data Retention and Deletion

- Data is retained only for business, security, and legal purposes.

- Verified deletion requests are processed within `30` days unless legal hold applies.
- Retention controls include logs, application records, and backup lifecycle management.
- Plaid-linked tokens and related records are deleted when accounts are disconnected or when deletion is requested, subject to legal/compliance obligations.
- Retention/deletion policy is reviewed periodically and enforced operationally.

10. Operational Security Cadence

- Weekly: review critical alerts/findings and backup health.
- Monthly: access review spot-checks, patch/vulnerability status review.
- Quarterly: privileged access review and policy/control checks.
- Annually: full policy review and incident-response exercise.

11. Attestation

`LifeTracker` attests that the controls described in this document are implemented as stated or have documented remediation plans and timelines where gaps are identified. The company will remediate Plaid-identified control gaps in good faith and according to agreed timelines.

Signed by: `Daniel Oliafa, Founder and Engineering Lead`
Date: `2026-04-10`